

Vendor Risk Management Policy

Status: Approved | Owner: [CISO / Compliance] | Version: 1.0 | Effective: [YYYY-MM-DD]

Note: This is a realistic sample, anonymized for testing. Replace bracketed items with your organization's details.

1. Purpose

Establish a risk-based approach to selecting, contracting, monitoring, and offboarding third parties with access to [Company] data or systems.

2. Scope

Applies to all vendors, sub-processors, and contractors handling Confidential or higher data classifications.

3. Definitions

- Tier 1 (Critical): Hosts production data or core services.
- Tier 2 (Important): Supports internal operations with limited data.
- Tier 3 (Low): No sensitive data; minimal operational impact.

4. Due Diligence (Pre-Contract)

- Security questionnaire (CAIQ-lite) and SOC 2/ISO 27001 report review for Tier 1/2.
- Data protection addendum (DPA), confidentiality clauses, and breach notification timelines in contracts.
- Risk acceptance by CISO for exceptions with documented compensating controls.

5. Onboarding

- Register vendor in the inventory with owner, tier, data flows, and controls.
- Limit access to least privilege; enforce MFA and IP allowlists when feasible.

6. Ongoing Monitoring

- Annual review of security reports for Tier 1/2; track remediation items.
- Continuous monitoring signals where available (attack surface ratings, breach news).

7. Offboarding

- Disable all vendor access; certify return/deletion of data; retain exit artifacts.

8. Metrics

- % vendors with current SOC 2/ISO reports; # of high-risk vendors with overdue action plans.

9. Evidence & Artifacts

- Signed DPAs; SOC 2/ISO reports; questionnaire responses; access audit logs; offboarding attestations.

10. Version History

Revision Log

v1.0 – Initial release [YYYY-MM-DD]

v1.1 – Added continuous monitoring step [YYYY-MM-DD]

11. SOC 2 Mapping

CC9.1–CC9.3, CC6.3 (vendor access), C1 (confidentiality).